Daily Work Log — 28 October 2026

Free Entra ID Hardening · Break-Glass Administrators · Repository Housekeeping

What was done today, why, and the evidence — with screenshots. Tenant ID, object IDs and the tenant domain are masked because this repository is public.

Project	Healthcare IAM Operations Simulation — Horizon Valley Medical Center (HVMC)
Environment	Microsoft Entra ID (Free tier, security defaults on) · GitHub repository dae-6-month-Sabi
Prepared By	Sabitha S Karanavar
Date	October 28, 2026
Cost	$0 — Entra ID Free features only, no Azure subscription used

Summary of the day

#	Work	Reference	Result
1	Tenant settings hardened: app consent, app/tenant/group creation, guest invitations and access, self-service sign-up	HVMC-IAM-CHG-106 · risk R08	**Done, verified**
2	Two emergency-access (break-glass) Global Administrators created; MFA registered; sign-in tested	HVMC-IAM-CHG-107 · risk R04	**Done, verified**
3	Break-glass passwords stored offline; the temporary password file deleted	—	**Done**
4	IAM hands-on report updated with Step 7 (v1.1) and pushed	commit 922f603	**Pushed**
5	Field-day presentation moved to semester_5 with the Keynote version	commit 30bd864	**Pushed**
6	Root .gitignore added; .DS_Store files and the smart_deal .env removed from GitHub	commit 9198318	**Pushed**
7	Checked: Cloud Infrastructure report already in the repository (commit 9c0b558)	—	No action needed

1. Tenant settings (HVMC-IAM-CHG-106, risk R08)

Why. Out of the box, every user could let a third-party app access their data ("user consent") — the route used by **consent-phishing** attacks, where a fake app asks for access to mail or files. Users could also

register apps, create tenants and groups outside the IAM process, and *anyone, even a guest*, could invite more guests. In a hospital handling ePHI these decisions belong to administrators.

How. The script `step7_tenant_hardening/tenant_hardening.py` first showed a dry run (no changes), the change was approved, then applied with `--apply`; the policy was saved before and after, and re-read from the tenant to confirm.

Setting	Before	After
Users can consent to applications	Yes	**No — an admin decides**
Users can register applications	Yes	**No**
Users can create new tenants	Yes	**No**
Users can create security groups	Yes	**No**
Who can invite guests	Everyone, including guests	**Admins and the Guest Inviter role only**
What guests can see in the directory	Limited access (default)	**Restricted to their own directory object**
Email-verified self-service sign-up	Yes	**No**
Self-service sign-up for subscriptions	Yes	**No**

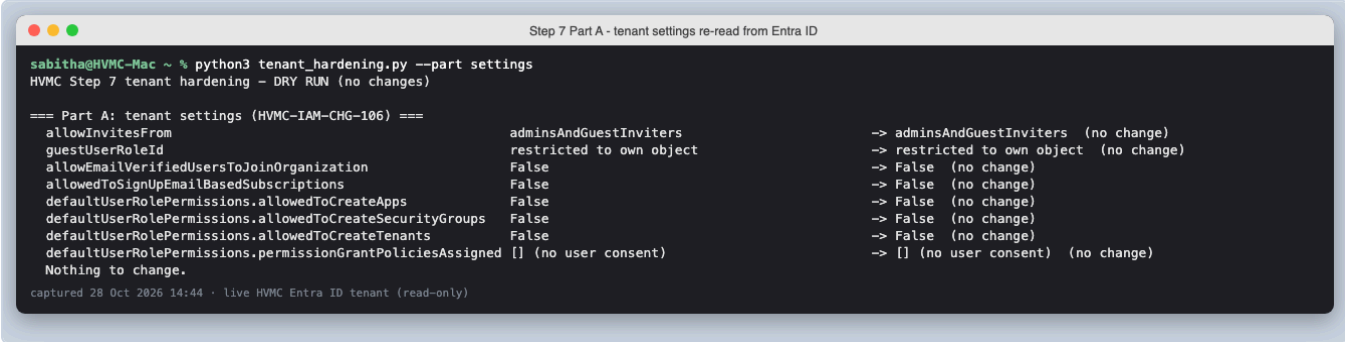


Figure 1. Settings re-read from Entra ID after the change: all eight match the target (“no change” needed).

2. Break-glass administrators (HVMC-IAM-CHG-107, risk R04)

Why. The tenant had exactly **one Global Administrator**. If that one account were locked, lost its phone or forgot its password, nobody could manage HVMC's identities. Microsoft recommends two cloud-only **emergency-access ("break-glass") accounts**. A staff member was not made a permanent Global Administrator, because that would break the least-privilege decision D2 from the RBAC design.

Control	How it was done
Two accounts, cloud-only	bg-admin-01 and bg-admin-02 on the tenant's .onmicrosoft.com domain — no dependency on any other system
Strong passwords, never shown	40 random characters each (~250 bits). The script never printed them; they went to a file readable only by the owner
Stored offline	Copied to a password manager / printed and sealed; the file was then deleted (Figure 8)
MFA	Security defaults made each account register Microsoft Authenticator at first sign-in (Figures 3–7)
Emergency use only	No licence, no groups, no app access; Authenticator entries named HVMC BREAK-GLASS 01 / 02
Tested	Each account signed in and showed the Global Administrator role; next test about 28 January 2027

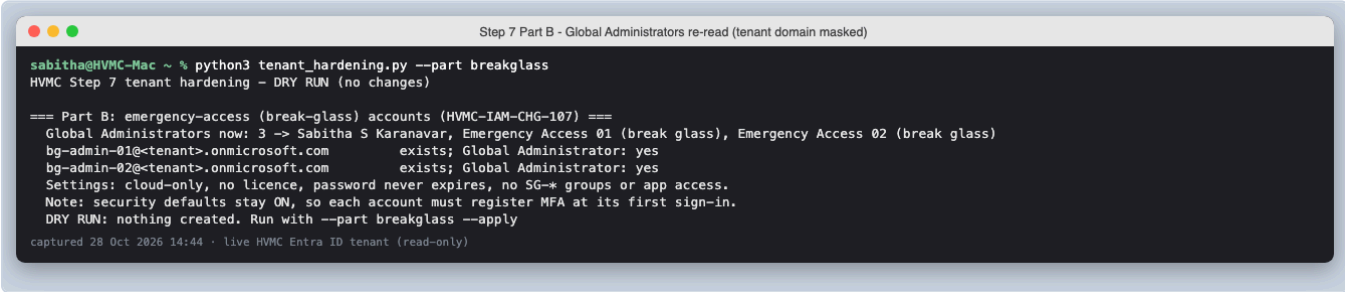


Figure 2. Global Administrators re-read from the tenant: from 1 to 3 (tenant domain masked).

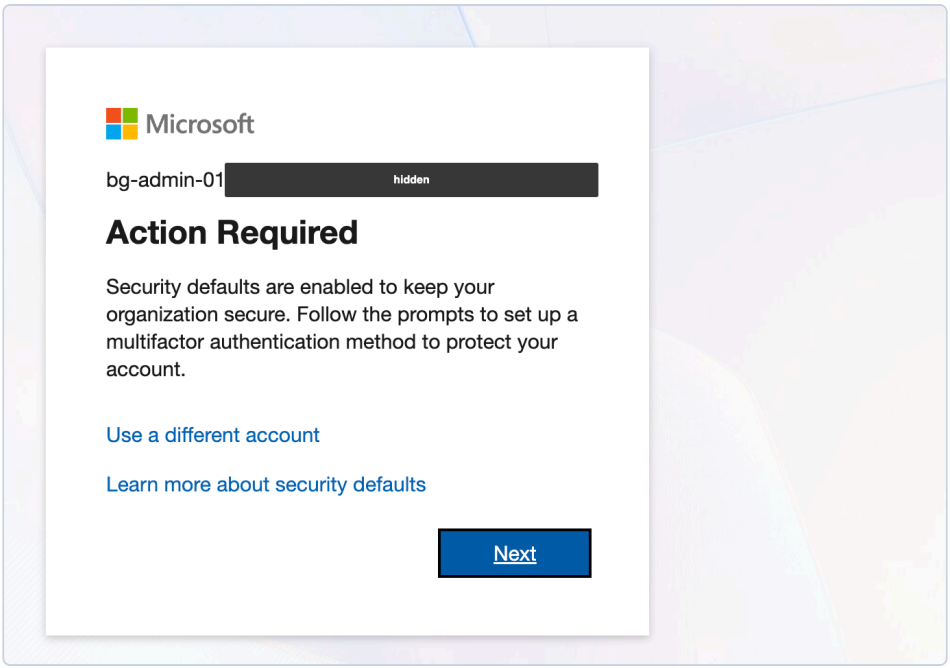


Figure 3. First sign-in of bg-admin-01: security defaults require MFA before anything else.

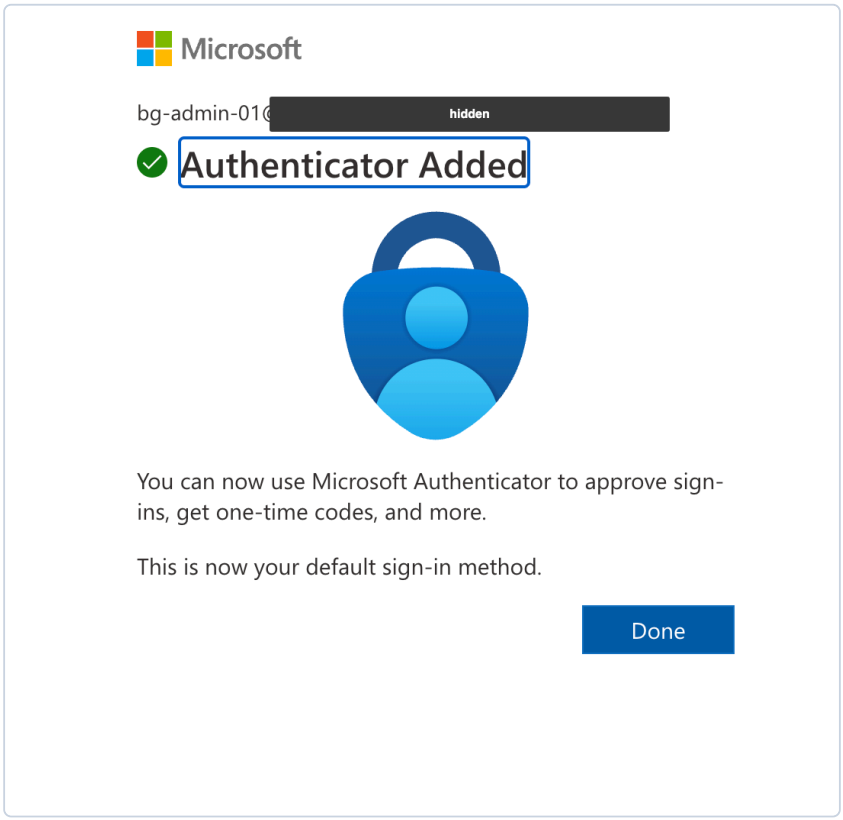


Figure 4. bg-admin-01: Microsoft Authenticator registered as the sign-in method.

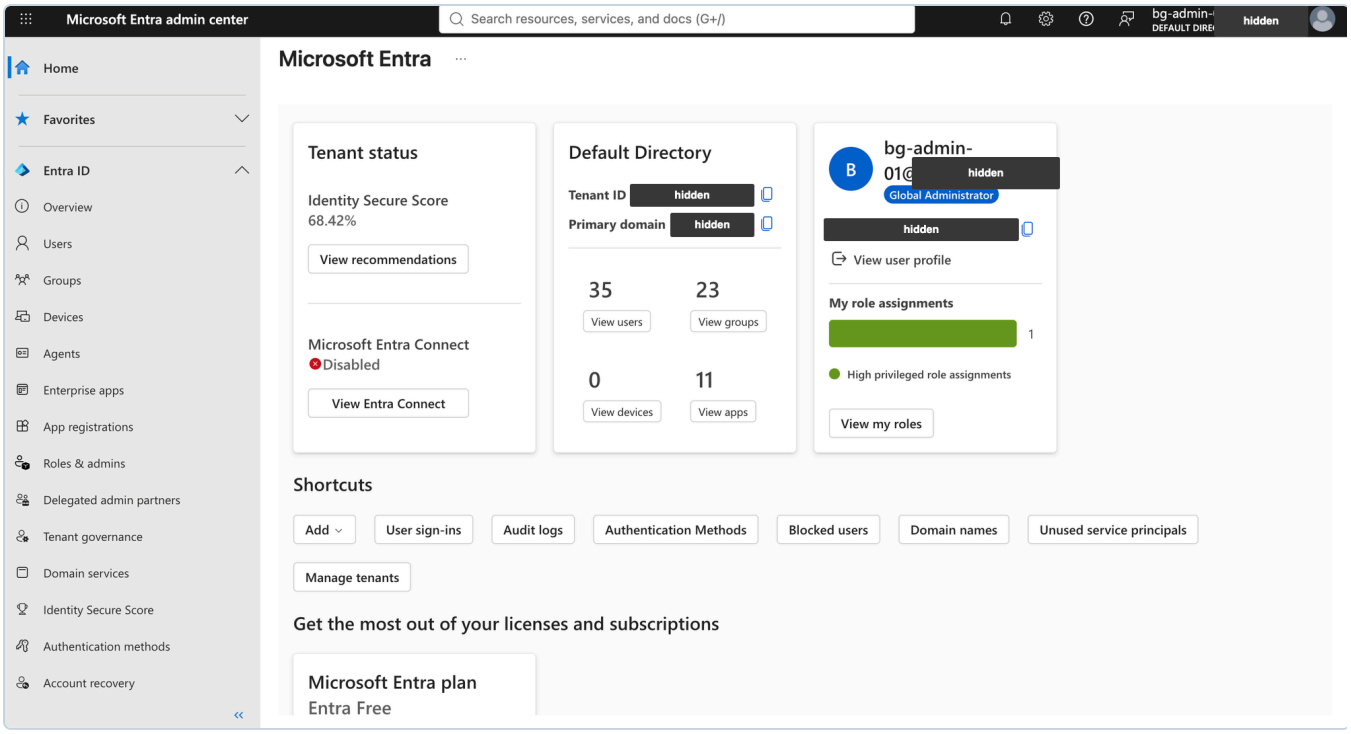


Figure 5. bg-admin-01 signed in to the Entra admin center with the Global Administrator role (IDs masked).

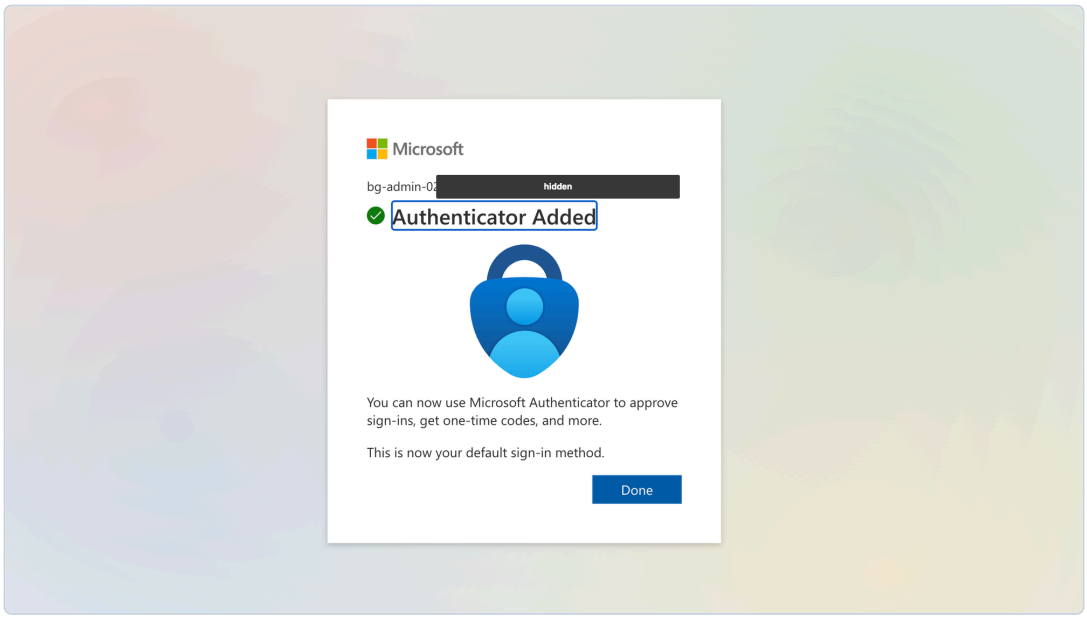


Figure 6. bg-admin-02: Microsoft Authenticator registered.

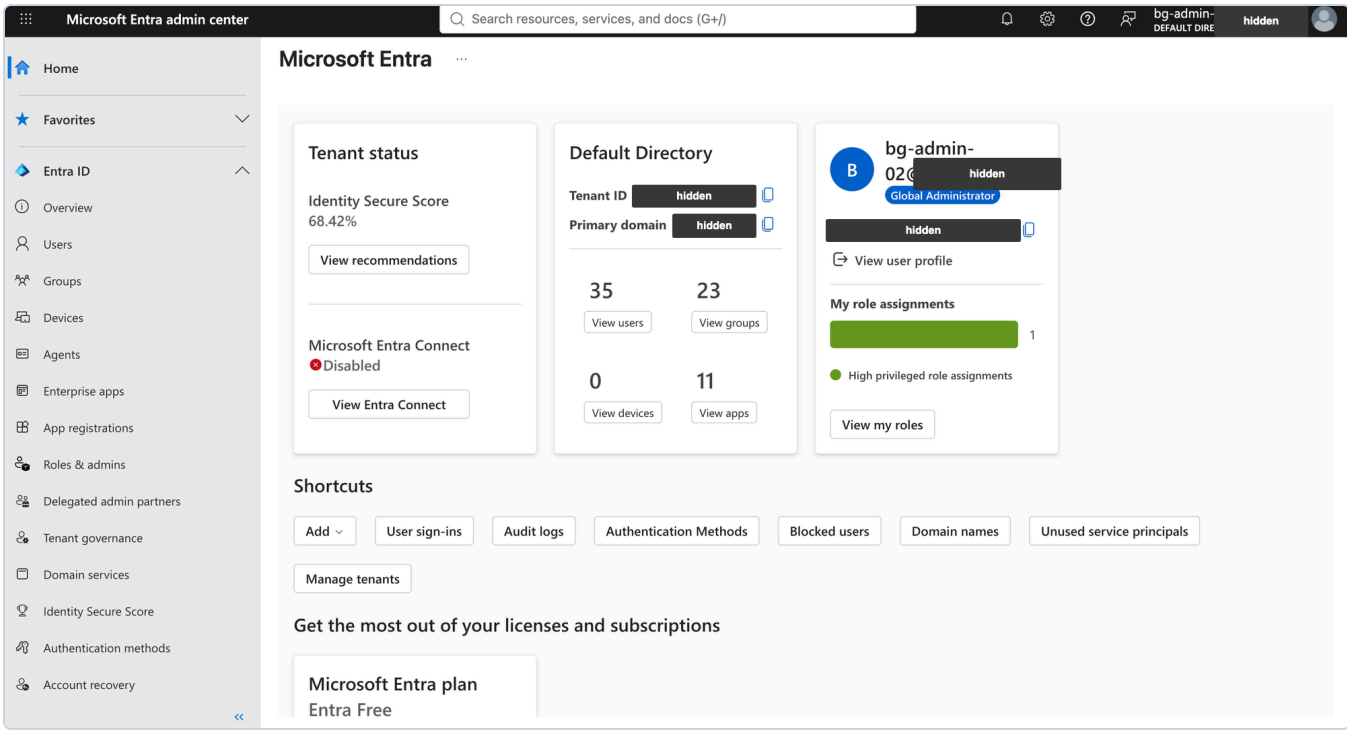


Figure 7. bg-admin-02 signed in with the Global Administrator role (IDs masked).

3. Password file deleted

After both passwords were saved offline, the temporary file `SECRET_breakglass_credentials.txt` was deleted permanently (not via the Trash). It was never committed: `.gitignore` rules block `SECRET_*` files.

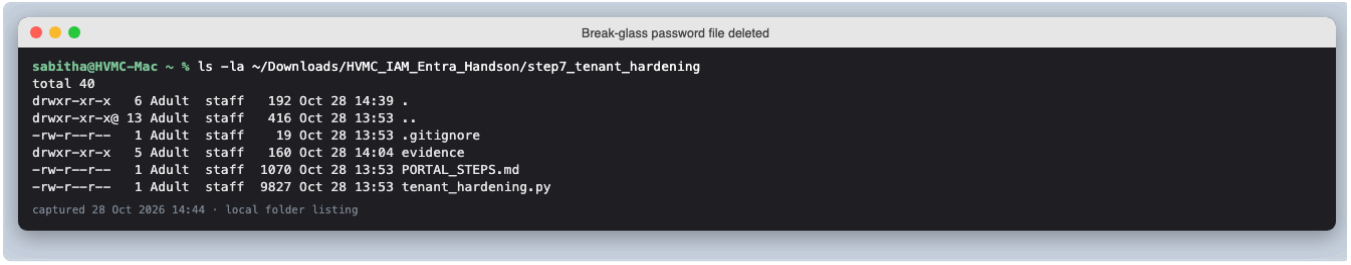


Figure 8. The step 7 folder after deletion: only the script, the portal fallback steps and local evidence remain.

4. Repository housekeeping

4.1 Field-day presentation

The presentation had been moved on the Mac into a new folder `semester5_Field_Day_Presentation` (present in both semester_4 and semester_5). The move was saved to GitHub under **semester_5**, together with the Keynote version *AccessGuard_Health_Presentation*; the old Semester_3 copy was removed, so GitHub holds one copy.

4.2 Root .gitignore

Why. The repository is public. A `.gitignore` lists files Git must never upload. Two problems were fixed: the `smart_deal/.env` file holding an API key had been uploaded, and 27 macOS `.DS_Store` files (Finder view settings) cluttered every change. Both are now removed from GitHub (the local files are kept) and blocked for the future, together with `SECRET_*` files and private keys.

> **Still to do:** a .gitignore only protects future commits. The old API key remains in the repository history, so it must be **regenerated at serpapi.com**.

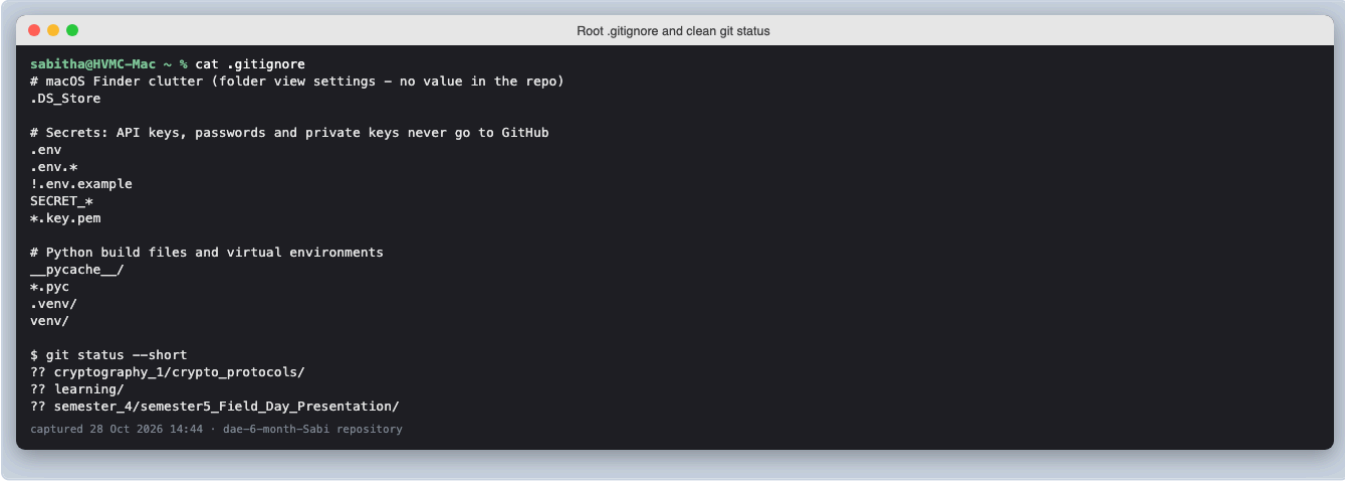


Figure 9. The new root .gitignore and a clean git status (only intentional local folders untracked).

4.3 Cloud Infrastructure report

Checked that *HVMC_Cloud_Infrastructure_Security.pdf* and its 41 supporting files are already on GitHub (commit 9c0b558, 15 October) and identical to the local copy. Only an empty placeholder evidence folder was left out on purpose.

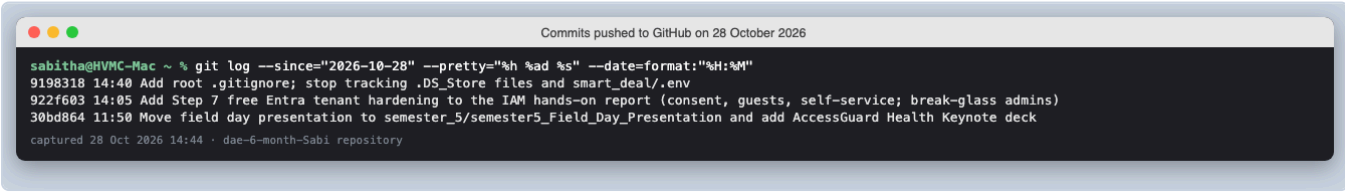


Figure 10. Today's three commits pushed to GitHub.

5. What I learned

- **One admin is a single point of failure.** Emergency-access accounts are a standard control, but only if their passwords are stored safely and they are tested regularly.
- **Secure defaults matter.** Microsoft's defaults favour convenience (anyone may invite guests or consent to apps); an organisation handling health data should tighten them on day one.
- **Check before you trust a link** — aka.ms is Microsoft's official short-link service; the address bar should show login.microsoftonline.com before a password is typed.
- **Public repositories need guard rails:** a .gitignore prevents leaks, but leaked secrets must still be rotated.

6. Next steps

Action	When
Regenerate the SerpAPI key at serpapi.com	29 Oct 2026
Reset the 30 staff passwords (random, change at first sign-in) and delete the bulk-create CSV	29 Oct 2026
Rename the HVMC admin entry in Authenticator to “HVMC ADMIN (Sabitha)” (optional)	When convenient
Quarterly break-glass sign-in test	About 28 Jan 2027
Paused: Cryptographic Protocols rubric; HVMC-CLIENT01 at home	Later